

TEMPLATE P14 · AI SUPPLIER ASSESSMENT

AI supplier assessment

Determines the requirement level of an AI supplier, assesses its capability, its guarantees and the dependency it creates, and checks that the contract includes the key clauses.

IN THIS DOCUMENT

01	Instructions for use	06	Conclusion
02	Identification	07	Quality criteria
03	Requirement level	08	Approval and verification
04	Supplier assessment	09	Version control
05	Key contractual clauses		

Legal notice and disclaimer. SEVEN-G is a reference methodological framework provided "as is" and for information purposes only. It does not constitute legal, regulatory, financial or professional advice, nor does it guarantee compliance with any law or standard. References to general regulation (such as the EU AI Act, the GDPR, DORA or NIS2), to technical standards and to regulation specific to each sector or jurisdiction may be incomplete, may not apply to a particular case or may become out of date as a result of regulatory changes, interpretations or supervisory positions after their consultation date. **Each organisation that uses SEVEN-G is solely responsible for identifying the regulation that applies to it, verifying that it is current and certifying its own regulatory compliance,** with the appropriate qualified advice. The author and SEACHAD accept no liability for any use made of this content or for any decisions taken on the basis of it. The data, figures, companies and cases in the examples are fictitious or illustrative.

01

Instructions for use

Aspect	Guidance
When it is used	In phase 3, before G3, for each supplier that provides AI models, platforms, data or services to the initiative. It is reviewed before signing or renewing the contract, when the supplier changes its model or terms, and at the frequency set by the requirement level.
Who completes it	The AI Technical Owner, with procurement and the AI Risk Owner. Information security, data protection and legal counsel are consulted.
Who verifies it	Lite: AI Risk Owner; if the AI Risk Owner has prepared the assessment, the AI Office or the AI Auditor verifies it. Enterprise: AI Auditor.
Who decides	It is approved with G3: AI Sponsor with risk clearance (Lite) · AI Committee (Enterprise).
Gate at which it is reviewed	G3 · Feasibility; check of signed clauses at G5.
Tool	T09 · AI supplier register.

Aspect	Guidance
Lite versus Enterprise	The depth depends on the requirement level (N1, N2, N3), not only on the intensity. Lite may omit the fields marked (Enterprise) if the supplier is N1.

Completion rules:

- The requirement level is determined by the **most demanding factor**.
- The requirements by level in this template are **indicative**; the definitive ones are set in document 36.
- *This document does not constitute legal advice.* References consulted in September 2026; their currency must be verified.

02

Identification

Field	Content	Guidance
Initiative code	IA-AAAA-NNN.	
AI systems affected	Codes from P05.	
Supplier	Registered name and country of establishment.	
Service or component assessed	Model via API, platform, software with embedded AI, data, professional services.	
Sourcing option	Build · Buy · Partner.	
Document version		
Date	DD-MM-AAAA.	
Author	Name and role.	

Requirement level

Factor	N1 Standard	N2 Enhanced	N3 Critical	Assessment
Service criticality	Support for non-critical internal tasks	Relevant process or with exposure to customers	Critical or important function, or subject to operational resilience regulation	N1 · N2 · N3
Data processed	No personal data or confidential information	Personal data or confidential information	Special categories, large volumes of personal data or critical confidential information	
Autonomy	A0 Assistance or A1 Recommendation	A2 Supervised action	A3 Autonomous action	
Substitutability	Replaceable within weeks without relevant impact	Replaceable with significant effort and cost	Hard to replace within a reasonable time frame	

Field	Content	Guidance
Requirement level		N1 Standard · N2 Enhanced · N3 Critical. The highest of the four factors.
Justification		
ICT third-party service provider supporting critical or important functions (DORA)		Yes · No · Not applicable. Only entities subject to DORA.

(illustrative example) Supplier of a language model via API for the enquiries assistant: criticality N2 (exposure to customers), data N2 (personal data from orders), autonomy N1 (A0), substitutability N2. Level: **N2 Enhanced**.

Supplier assessment

Result per block: **Conformant** · **Conformant with observations** · **Nonconformant** · **Not assessed**.

4.1 Capability and performance

Field	Content	Result	Guidance
Performance in the use case			Results of in-house tests with representative data (P10), not only the supplier's figures.
Model or service documentation			Intended purpose, known limitations, evaluation results, instructions for use.
Version and change management			Advance notice of model changes, ability to pin a version, version deprecation.
Service levels			Availability, response times, support.

4.2 Data, privacy and intellectual property

Field	Content	Result	Guidance
Use of the company's data			Whether it uses inputs, outputs or data to train or improve its models; it must be possible to opt out.
Status as processor			Data processing agreement in accordance with the GDPR when it processes personal data on behalf of the company.
Location and international transfers			Countries of processing and applicable safeguards.
Sub-processors and supply chain			List, notification of changes and right to object.
Retention and deletion			Periods and certification of deletion.
Ownership of outputs and protection against claims			Ownership of the outputs and the supplier's commitments in the event of third-party intellectual property claims.
Origin of the training data (Enterprise)			Available information on licences and provenance.

4.3 Security

Field	Content	Result	Guidance
Certifications and independent reports			For example, ISO/IEC 27001 or ISO/IEC 42001 , with a scope that covers the service.
AI-specific controls			Protection against prompt injection, isolation between customers, content filtering.
Incident management and notification			Notification time limits compatible with the company's obligations.
Identity and access (Enterprise)			Authentication, key management, access logs.

4.4 Regulatory compliance

Field	Content	Result	Guidance
Role of the supplier under the EU AI Act			Provider of the system, provider of a general-purpose AI model or other.
Information it provides to enable compliance			Documentation and instructions the company needs according to its own role (P11).
Compliance commitment			Declarations and cooperation with the company and with the authorities.
Sector-specific requirements (Enterprise)			DORA , NIS2 or other regulation applicable to the company.

4.5 Dependency, continuity and exit

Field	Content	Result	Guidance
Concentration			Other company systems that depend on the same supplier (T09).
Portability			Export formats for data, configurations, prompts and logs.
Alternatives			Alternative suppliers or solutions identified.

Field	Content	Result	Guidance
Supplier soundness and continuity (Enterprise)			Financial position, continuity plans, testing.
Exit plan (Enterprise)			Steps, time frame and cost of replacement. Mandatory at N3.

05

Key contractual clauses

Status: **Included** · **Under negotiation** · **Not included** · **Not applicable**. Indicative requirement: **M** mandatory · **R** recommended · — not required.

#	Clause	Minimum content	N1	N2	N3	Status
1	Service description and service levels	Scope, availability, support, penalties.	M	M	M	
2	Use of data	Prohibition or conditions on the use of data, inputs and outputs for training or improvement.	M	M	M	
3	Data protection	Data processing agreement, sub-processors, transfers, assistance with rights and assessments.	M	M	M	
4	Confidentiality	Scope and duration.	M	M	M	
5	Security	Minimum controls, certifications and the obligation to maintain them.	R	M	M	
6	Incident notification	Time limits, content and cooperation in the investigation.	R	M	M	
7	Changes to the model or the service	Advance notice, pinned versions, right to terminate if the change affects compliance or performance.	R	M	M	
8	Intellectual property	Ownership of outputs and protection against third-party claims.	R	M	M	
9	Regulatory compliance	Information and cooperation for the obligations under the EU AI Act and other regulations.	R	M	M	
10	Audit and access	Right of audit, reports and access for supervisors where appropriate.	—	R	M	

#	Clause	Minimum content	N1	N2	N3	Status
11	Subcontracting	Authorisation, list and the supplier's liability for its subcontractors.	—	R	M	
12	Location of processing	Permitted countries and notification of changes.	R	M	M	
13	Continuity and resilience	Continuity plans and testing.	—	R	M	
14	Exit and reversibility	Return of data, migration assistance, transition period, certified deletion.	R	M	M	
15	Liability and insurance	Liability limits consistent with the risk; insurance.	R	R	M	
16	Termination	Grounds, including regulatory or security breaches.	M	M	M	

For entities subject to [DORA](#), contracts with ICT third-party service providers must include the key contractual provisions required by that regulation, enhanced when the service supports critical or important functions.

06

Conclusion

Field	Content	Guidance
Overall result	Conformant · Conformant with observations · Nonconformant.	
Observations and conditions	What must be resolved, owner and deadline (before signature or before G5).	
Risks for P12	Risks in the TER category or others identified in the assessment.	
Review frequency	Indicative: N1 every two years or on renewal; N2 annually; N3 annually and upon any relevant change. Document 36 sets the definitive frequency.	
Next review	Date.	

A **Nonconformant** result in blocks 4.2 or 4.3, or a mandatory clause not included, prevents the supplier from being used with production data.

07

Quality criteria

The formal G3 criteria are in document 21 (see criteria G3.xx) and the third-party requirements in document 36.

#	Check	Status
1	The requirement level is justified with the four factors.	Met · Not met · Not applicable · Pending
2	Performance has been checked with in-house tests.	
3	The supplier's use of data is resolved by contract.	
4	The mandatory clauses for the level are included or under negotiation with a date before G5.	
5	Dependency and exit have been assessed; at N3 there is an exit plan.	
6	The risks identified have been carried over to P12.	
7	The supplier is registered in T09 and in record P05.	

08

Approval and verification

Function	Role in SEVEN-G	Name and position	Date	Signature or reference
Prepares	AI Technical Owner			
Consulted	Procurement · security · data protection · legal counsel			
Issues clearance	AI Risk Owner			

Function	Role in SEVEN-G	Name and position	Date	Signature or reference
Verifies	AI Risk Owner (Lite) · AI Auditor (Enterprise)			
Decides	AI Sponsor with risk clearance (Lite) · AI Committee (Enterprise)			

Segregation of duties: whoever negotiated the contract does not verify the assessment; anyone with a conflict of interest with the supplier declares it in P03.

09

Version control

Completed document

Version	Date	Author	Changes
---------	------	--------	---------

Template

Version	Date	Changes
0.1	16-09-2026	First version. N1–N3 requirement levels of the common specification §5.6, assessment by blocks and key contractual clauses. Requirements by level indicative until document 36.

External sources cited

Links to the official or primary source, checked before publication. Always verify the version in force on the date of use.

Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive) · <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng> · Parlamento Europeo y Consejo de la UE · 14-12-2022

Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free

movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) · <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> · Parlamento Europeo y Consejo de la UE · 27-04-2016

Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector (DORA) · <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng> · Parlamento Europeo y Consejo de la UE · 14-12-2022

Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act) · <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> · Parlamento Europeo y Consejo de la UE · 13-06-2024

ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements · <https://www.iso.org/standard/27001> · ISO/IEC (JTC 1/SC 27) · 25-10-2022
